MacZine
THE MACTECH SOLUTIONS NEWSLETTER
ISSUE Nº 014 · AUGUST 2026 · MACTECHSOLUTIONSLLC.COM/MACZINE

FIELD REPORT · CRYPTOGRAPHY

FIPS 140-3 Is the Control That Fails Quietly

Encryption that is strong is not the same as encryption that is validated. The distinction costs 5 SPRS points and it is invisible until an assessor looks.

BY **MACTECH SOLUTIONS** READING TIME · 4 MIN NIST-800-171 · CUI · CUI-ENCLAVE · CMMC

Most control failures announce themselves. Multifactor authentication is either in front of you at login or it is not. Logging either produces records or it does not. The cryptography requirement is different, and that is what makes it dangerous: a system using unvalidated cryptography behaves in every observable way like a system using validated cryptography. It encrypts. The traffic is unreadable. Nothing breaks.

It simply does not satisfy the control, and nobody finds out until somebody checks a certificate number.

FIELD COPY
ISSUE Nº 014
NIST 800 171

The distinction the requirement actually draws

NIST SP 800-171 does not ask whether you encrypt CUI. It asks whether you employ *validated* cryptography when doing so.

Validation is a specific process. A vendor submits a cryptographic module to the Cryptographic Module Validation Program, an accredited lab tests it against the FIPS 140-3 standard, and on success it receives a certificate - with a number, a defined boundary, and an approved mode of operation. Absent that certificate, the module has not been validated no matter how sound its mathematics.

This is why AES-256 is not an answer to the question. AES is an approved algorithm; the control is about the *implementation* of the algorithm. An open-source library implementing AES-256 flawlessly, but never submitted for validation, does not satisfy the requirement. The requirement is not "is this good crypto." It is "has this specific implementation been tested by an accredited lab and certified."

Reasonable engineers find this maddening, and the objection has merit as engineering. It has none as compliance. The control says validated.

5

SPRS POINTS LOST WHEN VALIDATED CRYPTOGRAPHY IS NOT IN PLACE

◆ VALIDATED, NOT CERTIFIED

A module is **validated** by the Cryptographic Module Validation Program and receives a certificate number. Vendor claims of being "FIPS compliant" or "using FIPS algorithms" are not the same thing - the certificate number is the evidence.

The three ways programs fail it

The vendor's marketing did the assessment. A product page says "FIPS compliant." That phrase means nothing in particular and is not a claim of validation. "FIPS 140-2 validated, certificate #XXXX" is a claim of validation. The gap between these two sentences accounts for a large share of findings, and the only remedy is to look up the certificate rather than the brochure.

The module is validated but not running in approved mode. This is the subtle one and it catches sophisticated teams. Many products ship a validated module that operates in FIPS mode only when explicitly configured. Installed at defaults, the certificate is real and irrelevant, because the system is not using the module the way the validation covers. Windows has a policy setting for this. So do most databases, VPN concentrators, and storage platforms. Somebody has to turn it on and evidence that it is on.

The boundary has an exception nobody mapped. The enclave is configured correctly and then CUI leaves it through a path that was never in the cryptographic inventory - a backup target, a monitoring agent shipping telemetry, a file-transfer utility a team adopted for one project. Each is encrypted in transit by something. Whether that something is validated is a question nobody asked, because nobody knew the path existed.

Looking a certificate up

The check itself is unglamorous and takes about a minute per module, which is why there is no excuse for skipping it.

The CMVP publishes a searchable list of validated modules. What you are matching is not the product name but the module name and version, and those frequently differ from the marketing name in ways that matter - a suite may be validated in one component and not another, or validated at a version you are not running. A certificate that covers version 2.1 says nothing about the 2.3 you deployed last spring.

Read three fields when you find the entry. The **module name and version**, against what is actually installed. The **validation status** - certificates move to historical as standards transition, and a historical certificate is a planning problem you want to find early rather than a finding. And the **security policy** document, which defines the approved mode and is the only authoritative statement of what you have to configure for the validation to apply to you.

What to actually do

Inventory the paths first, not the products. Every place CUI is written to disk and every path it traverses. That list is always longer than the architecture diagram suggests, and building it is most of the work - the certificate lookups afterward are mechanical.

For each path, record three things: the module doing the encryption, its CMVP certificate number, and the evidence that it is running in approved mode. A path where any of the three is blank is either a remediation item or a boundary you did not know you had. Both are worth finding before an assessor finds them.

That inventory is also the artifact that makes the control defensible later. "We use FIPS-validated cryptography" is an assertion. A table of paths, modules, certificate numbers, and configuration evidence is a demonstration, and demonstrations survive assessments.

MacTech's CUI enclave implementation is built around FIPS 140-3 validated cryptography as a property of the environment rather than a per-system configuration task - which is largely a way of saying the inventory above was done once, deliberately, instead of reconstructed under assessment pressure. ◆◆